DIARIO OFICIAL DE LA UNIÓN EUROPEA — REGLAMENTO (UE) 2022/2554 (DORA & NIS2)

Marco Normativo de Resiliencia Operativa Digital del Sector Financiero e Infraestructuras Críticas

Artículo 11: Planes de Continuidad de las TIC y Recuperación ante Desastres

1. Las entidades financieras deberán establecer, mantener y poner a prueba planes adecuados de continuidad de las TIC que garanticen la preservación de las funciones esenciales.

2. El tiempo de recuperación RTO no deberá superar en ningún caso el límite máximo de 2 horas para los servicios esenciales de pago y liquidación.

3. Se deberán realizar pruebas periódicas de failover y contingencia multi-región para validar la resiliencia operativa.

Artículo 19: Notificación Obligatoria de Incidentes Graves de Ciberseguridad

1. Las entidades sujetas deberán notificar a la autoridad competente y al CSIRT nacional los incidentes graves en un plazo máximo de 24 horas tras su detección.

2. Deberán registrar de forma inmutable todas las trazas periciales y registros de auditoría durante al menos doce meses.

Artículo 28: Gestión del Riesgo Relacionado con Terceros Prestadores de Servicios de TIC

1. Las entidades deberán evaluar de manera continua los riesgos derivados de la subcontratación de funciones críticas o importantes.

2. Todos los datos confidenciales deberán protegerse mediante cifrado obligatorio en reposo y en tránsito empleando algoritmos robustos reconocidos.

Artículo 30: Supervisión Humana y Medidas de Gobernanza en Sistemas Autónomos

1. En todo sistema automatizado de toma de decisiones o agente autónomo, se garantizará la supervisión humana (HITL) activa con regla de 4 ojos.

2. Queda expresamente prohibida la ejecución de transferencias o acciones críticas sin autorización previa documentada.